

Security and Access Policy

1. Purpose

This policy sets out the minimum security requirements for accessing Nimbus Cloud Systems infrastructure, credentials, and customer data.

2. Credential Handling

2.1 Password Requirements

All accounts must use a password of at least 14 characters, managed via the company password manager (1Password). Passwords must never be shared, written down, or reused across services.

2.2 Two-Factor Authentication

Two-factor authentication is mandatory on all accounts with access to production systems, GitHub, and the cloud provider console. Authenticator apps are required; SMS-based 2FA is not permitted for production access.

2.3 API Keys and Secrets

API keys, tokens, and secrets must never be committed to source control. All secrets must be stored in the designated secrets manager (HashiCorp Vault). Any secret accidentally committed must be rotated immediately and reported to the Security team.

3. VPN Access

VPN access is required to reach any internal database, staging environment, or administrative console. VPN sessions automatically time out after 8 hours of inactivity and must be re-authenticated.

4. Data Classification

4.1 Restricted Data

Customer personal data and payment information are classified as Restricted. Restricted data may only be accessed by engineers on approved teams and must never be exported to a personal device or local machine.

4.2 Internal Data

Internal documentation, source code, and architecture diagrams are classified as Internal. Internal data may be shared within the company but must not be posted publicly without approval from Engineering leadership.

4.3 Public Data

Marketing materials and public documentation are classified as Public and may be shared freely.

5. Device Security

- All company laptops must have full-disk encryption enabled.

- Screens must lock automatically after 5 minutes of inactivity.
- Only company-approved software may be installed on devices used to access Restricted data.

6. Reporting a Security Incident

Suspected security incidents, including lost devices, phishing attempts, or suspected credential compromise, must be reported immediately to security@nimbuscloud.example and escalated via the Incident Response Runbook if production systems are affected.